

Regulatory Framework

for Multi-Tier ZKP-Based eKYC

Mapping Indian Financial Regulations to ZKP Circuit Predicates

Contents

1	Overview: Why Regulation Shapes the Circuit	2
2	UPI Transaction Tier System	2
2.1	NPCI Tier Definitions	2
2.2	UPI Lite and Special Products	2
2.3	ZKP Implication	3
3	RBI KYC Master Directions (2016, Updated 2023)	3
3.1	Para 13: Customer Due Diligence (CDD) Requirements	3
3.1.1	Officially Valid Documents (OVDs)	4
3.2	Para 16: Simplified CDD for Low-Risk Customers	4
3.3	Para 27: Customer Risk Categorisation	5
3.4	Para 38: Periodic KYC Update Requirements	5
4	RBI Prepaid Payment Instruments (PPI) Master Directions 2021	6
4.1	Para 7: KYC Requirements for PPIs	6
4.2	Para 12: Interoperability	7
5	NPCI UPI Product Circulars	7
5.1	NPCI/UPI/OC No. 181 and Related Circulars	7
5.2	NPCI KYC Verification Mechanism (Current)	7
6	Digital Personal Data Protection Act 2023	8
7	Prevention of Money Laundering Act 2002 (PMLA)	9
8	Aadhaar (Targeted Delivery) Act 2016	10
9	IT Act 2000 and Related Provisions	11
10	Master Predicate Table: Regulations → Circuit	12
11	What the Circuit Must Incorporate: Summary	13

1 Overview: Why Regulation Shapes the Circuit

The ZKP circuit is not a purely mathematical construct — it is a **regulatory compliance engine**. Every predicate ($\phi_1 \dots \phi_n$) in the circuit corresponds directly to a statutory requirement. If a predicate is missing, the system is legally non-compliant. If a predicate is wrong, the system can be exploited or provides weaker guarantees than the regulation demands.

This document maps every relevant Indian regulation to the specific ZKP circuit predicates required in ZKProof-UPI. It serves as:

- The legal specification for the circuit designer
- Evidence of regulatory alignment for the NPCI/GPay pitch
- The compliance argument section of the research paper
- Documentation for the Faculty-in-Charge and C-DAC mentor

★ **Key Principle: Data Minimisation as Compliance**

The **Digital Personal Data Protection Act 2023** (Section 8(3)) mandates that personal data collected must be “limited to such personal data as is necessary for the specified purpose.” The ZKP circuit operationalises this principle mathematically: the verifier receives a boolean result ($\top$ or $\perp$) and nothing else. This is the most legally rigorous form of data minimisation possible.

2 UPI Transaction Tier System

2.1 NPCI Tier Definitions

The National Payments Corporation of India (NPCI) defines three access tiers for UPI, governed by the level of KYC completed by the account holder. These tiers apply to all PSPs operating on the UPI rails (GPay, PhonePe, Paytm, BHIM, bank apps).

array tabularx

2.2 UPI Lite and Special Products

✓ **NPCI Special Product Limits (for Extension Module)**

- **UPI Lite:** Rs. 500/transaction, max Rs. 2,000 wallet balance. No PIN required. *No KYC required.* Intended for everyday micro-payments.
- **UPI Lite X:** Rs. 1,000/transaction. Offline-capable NFC payments.
- **UPI One World (NRI/Tourist):** Requires NRE/NRO account with Full KYC. Limited to Rs. 1,00,000/month. FEMA compliance mandatory.

Tier	Limit (per txn)	Monthly Cap	P2P Allowed	Cash Withdrawal
No KYC	Rs. 0	Rs. 0	No	No
Minimum KYC	Rs. 10,000	Rs. 1,00,000	No	No
Full KYC	Rs. 1,00,000	Unlimited	Yes (Rs. 50,000/mo)	Yes (limited)
Merchant (verified)	Rs. 5,00,000	Unlimited	N/A	N/A
Capital Market / Insurance	Rs. 5,00,000	Unlimited	N/A	N/A

Table 1: UPI Wallet KYC Tiers and Transaction Limits

- **UPI 123PAY (feature phones):** Rs. 5,000/day. No smartphone required. Basic KYC sufficient.
- **RuPay Credit on UPI:** Full KYC + credit bureau check required. Limit depends on credit limit.

2.3 ZKP Implication

The tier system defines the circuit’s output predicate space. The circuit does not simply prove “user is KYC verified” — it proves “user is **Full KYC verified and eligible for the requested tier.**” This requires the circuit to encode all tier conditions as arithmetic constraints.

3 RBI KYC Master Directions (2016, Updated 2023)

Reference: RBI/DBR/2015-16/18, Master Direction — Know Your Customer (KYC) Direction, 2016. Most recently updated January 4, 2023.

3.1 Para 13: Customer Due Diligence (CDD) Requirements

§ RBI KYC Para 13 — Individual Customer Identification

For individual customers, Regulated Entities (REs) must obtain and verify:

1. **Para 13(a):** Name, date of birth/age, address (current and permanent), mobile number, email ID (where available).

2. **Para 13(b):** One Officially Valid Document (OVD) for proof of identity and one for proof of address (may be the same document).

3. **Para 13(c):** Permanent Account Number (PAN) or Form 60 (if PAN not

available). PAN is mandatory for accounts above Rs. 50,000.

4. **Para 13(d):** Aadhaar for V-CIP (Video-based Customer Identification Process) and for digital-only onboarding.

3.1.1 Officially Valid Documents (OVDs)

The following documents are defined as OVDs under Para 3(xlvii) of the KYC Directions:

Code	Document	Encodes in Circuit
1	Passport	docType = 1
2	Driving Licence	docType = 2
3	Voter’s Identity Card	docType = 3
4	Permanent Account Number (PAN) Card	docType = 4
5	Aadhaar Letter / e-Aadhaar	docType = 5
6	NREGA Job Card	docType = 6
7	National Population Register Letter	docType = 7

π Circuit Predicate ϕ_{doc} : OVD Validity

Requirement: docType must be a valid OVD code (1–7).
Circuit constraint: $\phi_{doc} := 1 \leq docType \leq 7$
Private: actual docType value
Public: nothing (verifier only learns that a valid OVD was used)

3.2 Para 16: Simplified CDD for Low-Risk Customers

§ RBI KYC Para 16 — Simplified CDD

For low-risk customers, REs may apply Simplified CDD:

- One document serving as both ID and address proof
- Aadhaar with recent photograph is acceptable
- No PAN required if transaction amounts remain below thresholds
- Periodic update every 10 years (vs. 2 years for high-risk)

Applicable to: Salaried employees of government/public sector, professionals (doctors, engineers, CAs), pensioners, and students (for Minimum KYC tier).

3.3 Para 27: Customer Risk Categorisation

§ RBI KYC Para 27 — Risk Categories

All REs must categorise customers into one of three risk categories:

Category	Profile	Income Class Code
Low Risk	Salaried employees (central/state/PSU)	1
	Professionals (doctors, CAs, lawyers)	1
	Pensioners	3
Low-Medium Risk	Self-employed businesspersons	2
	Farmers (with land records)	2
Medium Risk	Others not in Low or High	2
High Risk	Politically Exposed Persons (PEPs)	N/A
	Non-face-to-face customers	N/A
	High-value transaction accounts	N/A
Minimum KYC only	Students, casual workers	4

π Circuit Predicate ϕ_{income} : Income Class Verification

Full KYC requirement: $incomeClass \in \{1, 2, 3\}$ (excludes students)

Min KYC requirement: $incomeClass \in \{1, 2, 3, 4\}$

Constraint (Full KYC): $\phi_{income} := 1 \leq incomeClass \leq 3$

Private: actual income class and underlying income amount

Public: nothing (PSP only learns the tier result)

3.4 Para 38: Periodic KYC Update Requirements

§ RBI KYC Para 38 — Validity Periods

Risk Category	KYC Update Frequency
Low Risk	Every 10 years
Medium Risk	Every 8 years
High Risk	Every 2 years

For UPI Full KYC (primarily low-risk customers), the default validity window is **10 years**. The circuit enforces this by checking the credential issuance year.

π Circuit Predicate ϕ_{fresh} : Credential Freshness

Requirement: credential must have been issued within validity window

Constraint: $\phi_{\text{fresh}} := 0 \leq (\text{currentYear} - \text{issuanceYear}) \leq \text{maxValidityYears}$

Private: issuanceYear

Public: currentYear, maxValidityYears (10 for low-risk)

4 RBI Prepaid Payment Instruments (PPI) Master Directions 2021

Reference: RBI/DPSS/2021-22/82, Master Directions on Prepaid Payment Instruments, August 27, 2021 (as amended).

4.1 Para 7: KYC Requirements for PPIs

§ PPI Para 7 — Issuance Conditions

Small PPIs (Minimum KYC):

- Name and mobile number verified via OTP
- Maximum outstanding balance: Rs. 10,000 at any point
- Total loading in a financial year: Rs. 1,00,000
- Cannot be used for P2P transfers or cash withdrawal
- Permitted only for purchase of goods and services
- Can be issued without full KYC for 18 months; must be converted after

Full KYC PPIs:

- Complete KYC as per RBI KYC Master Directions 2016
- Maximum outstanding balance: Rs. 2,00,000
- Extendable to Rs. 5,00,000 for specific purposes (medical, education)
- P2P transfers allowed up to Rs. 50,000 per month
- Cash withdrawal permitted (up to Rs. 2,000/day from ATMs)
- Must be linked to a full-KYC bank account

4.2 Para 12: Interoperability

All PPIs must be interoperable with each other and with bank accounts through UPI from January 1, 2023 (RBI mandate). This means the ZKP proof generated for one PSP must be verifiable by *any* PSP on the UPI network — motivating the on-chain Solidity verifier design.

5 NPCI UPI Product Circulars

5.1 NPCI/UPI/OC No. 181 and Related Circulars

✓ NPCI UPI Transaction Limits and KYC Requirements

The following NPCI circular provisions directly shape the circuit's tier logic:

1. **Default transaction limit:** Rs. 1,00,000 per transaction for Full KYC accounts. Banks may set lower limits per their own risk policies.
2. **Enhanced limits (pre-approved):** Up to Rs. 5,00,000 for:
 - Capital market transactions (trading, mutual funds, IPO)
 - Insurance premium payments
 - Foreign inward remittances (NRI accounts)
 - Verified merchant payments
3. **P2P transfer limit:** Rs. 1,00,000 per transaction, Rs. 50,000 per transaction for small PPIs (Full KYC only).
4. **UPI AutoPay:** Recurring mandates up to Rs. 15,000 without PIN (above: PIN required). Full KYC required for amounts above Rs. 5,000.
5. **UPI Lite:** Rs. 500/transaction, wallet max Rs. 2,000. No KYC required. Not covered by the main ZKP circuit (see Extension Module).
6. **Cooling period for new accounts:** 24 hours before first UPI transaction over Rs. 25,000. ZKP credential freshness check covers this.

5.2 NPCI KYC Verification Mechanism (Current)

Currently, NPCI verifies KYC through:

1. PSP queries the bank's KYC status API
2. Bank confirms KYC tier and linked PAN/Aadhaar (via CKYC or in-house DB)
3. PSP stores the verification result and associated documents

ZKProof-UPI replaces Step 2–3: the user proves KYC eligibility via a Groth16 proof. The PSP only stores the proof and the boolean result. No documents.

6 Digital Personal Data Protection Act 2023

Reference: The Digital Personal Data Protection Act, 2023. No. 22 of 2023. Gazette of India Extraordinary, August 11, 2023.

§ DPDP Act 2023 — Key Provisions for ZKProof-UPI

Section 4: Grounds for Processing Personal Data

Personal data may be processed only with consent or for certain “legitimate uses.” KYC verification is a legitimate use; however, *the minimum necessary data* must be collected. ZKP ensures no personal data is processed by the PSP at all.

Section 5: Notice

The data principal (user) must be given notice of what data is collected and why. Under ZKP, the PSP collects nothing — the notice obligation is substantially reduced.

Section 6: Consent

Consent must be “free, specific, informed, unconditional.” The user consents to the proof generation on their device; they do not consent to document storage at the PSP because no documents are transmitted.

Section 8(3): Data Minimisation — CRITICAL

“A Data Fiduciary shall ensure that personal data processed by it is limited to such personal data as is necessary for the specified purpose.”

ZKP is the **mathematically optimal implementation** of this clause. The PSP receives exactly one bit of information (yes/no on tier eligibility) — nothing more. No implementation can achieve greater minimisation.

Section 8(4): Accuracy

Personal data must be accurate. Since personal data is not stored by the PSP, the accuracy obligation shifts entirely to the credential issuer (bank/UIDAI).

Section 8(7): Storage Limitation

“Personal data shall not be retained beyond the period necessary.” Under ZKP: retained period = 0 (PSP stores nothing). Complete compliance.

Section 17: Significant Data Fiduciary

Large PSPs (GPay, PhonePe) likely qualify as Significant Data Fiduciaries. ZKP *reduces* their SDFs obligations by eliminating the personal data processing that triggers SDFs requirements.

Section 26: Penalties

Up to Rs. 250 crore for breach of obligations. ZKP eliminates the primary data breach risk vector (PSP storing KYC documents).

π Circuit Predicate $\phi_{\text{zero-knowledge}}$: DPDP Compliance

The zero-knowledge property of Groth16 ensures:

$$\text{View}_{\mathcal{V}}(\mathcal{P} \leftrightarrow \mathcal{V}) \stackrel{\text{comp}}{\approx} \text{Sim}(x)$$

This means the verifier's view is computationally indistinguishable from a simulated transcript that uses **no** private data. This is the formal cryptographic guarantee that maps directly to Section 8(3) compliance.

7 Prevention of Money Laundering Act 2002 (PMLA)

Reference: Prevention of Money Laundering Act, 2002 (No. 15 of 2003), as amended. Prevention of Money Laundering (Maintenance of Records) Rules, 2005.

§ PMLA Key Provisions**Rule 9: Maintenance of Records**

Reporting entities (banks, financial institutions, intermediaries) must maintain KYC records for a minimum of **5 years** from the date of transaction and **10 years** from the date of account closure.

ZKP implication: The credential issuer (bank) maintains the KYC record. The PSP (verifier) receives only the proof π and the boolean result. The PSP has no personal data to maintain under PMLA, substantially reducing their compliance burden.

Rule 9A: Customer Due Diligence (CDD) Measures

Reporting entities must:

1. Identify the customer and verify their identity using reliable documents
2. Understand the nature and purpose of the intended business relationship
3. Obtain information on source of funds for high-value transactions

ZKP implication: Identity verification (Step 1) is performed once by the credential issuer. The PSP uses the ZKP proof as evidence that CDD has been performed by a trusted issuer, without receiving the identity documents themselves.

Rule 9B: Enhanced Due Diligence (EDD)

For high-risk customers (PEPs, non-resident accounts), enhanced due diligence is required. ZKProof-UPI handles this by including `residenceStatus` and a PEP-exclusion flag in the circuit predicates.

Rule 14: Reporting Obligation

Suspicious transactions must be reported to the Financial Intelligence Unit (FIU-IND). The on-chain audit trail (Verifier contract events on Ethereum/Polygon) provides a tamper-proof log for regulatory audit without exposing personal data.

π Circuit Predicate ϕ_{sig} : Issuer Authentication (PMLA Compliance)**Requirement:** Identity verification must be performed by a Regulated Entity**Constraint:** $\phi_{sig} := \text{EdDSA.Verify}(pk_{\mathcal{I}}, \text{MerkleRoot}, \sigma) = 1$ **Public:** $pk_{\mathcal{I}}$ (issuer's registered public key, from on-chain registry)**Private:** σ (signature components R_s, S)**Legal effect:** Proves that the credential was issued by a PMLA-compliant RE, satisfying Rule 9A's verification requirement

8 Aadhaar (Targeted Delivery) Act 2016

Reference: The Aadhaar (Targeted Delivery of Financial and Other Subsidies, Benefits and Services) Act, 2016. No. 18 of 2016.

§ Aadhaar Act — Relevant Provisions

Section 8: Authentication

- Aadhaar authentication may only be performed by registered “requesting entities” (banks, SEBI-registered intermediaries, government bodies)
- Authentication result: UIDAI returns only **yes/no** — never the actual Aadhaar data
- UIDAI stores authentication meta-data for 6 months only
- Consent of Aadhaar holder is mandatory before any authentication

ZKP analogy: The ZKP proof is the cryptographic equivalent of UIDAI's yes/no authentication response. The credential commitment Poseidon(AadhaarHash, salt) in the Merkle tree replaces raw Aadhaar storage.

Section 8(2): Biometric Data Restriction

“Core biometrics shall not be used for any purpose other than generation of Aadhaar numbers and authentication.”

ZKP compliance: No biometric data enters the ZKP circuit. The circuit uses only demographic attributes (DOB, residence status, income class) derived from the Aadhaar XML — not fingerprints or iris scans.

Section 29: Restrictions on Sharing of Information

- Core biometrics **must not** be shared with anyone under any circumstances
- Aadhaar number may be shared with consent, but must be protected in transit
- Identity information collected for one purpose cannot be used for another

ZKP compliance: The Aadhaar commitment in the Merkle tree is a one-way hash: Poseidon(AadhaarHash, salt). Even if the Merkle tree is inspected, the raw Aadhaar

number cannot be recovered. The PSP never receives the Aadhaar number; they receive only the Merkle root signature, which proves the Aadhaar is *part of* the credential without revealing it.

Aadhaar Offline XML:

UIDAI provides an “Offline Aadhaar” XML document signed by UIDAI’s digital certificate. This XML contains demographic data and serves as the credential source in ZKProof-UPI. The user downloads it from the UIDAI portal once.

π Circuit Predicate ϕ_{aadhaar} : Aadhaar Inclusion

Requirement: Aadhaar must be linked and part of the verified credential

Circuit constraint: $\phi_{\text{aadhaar}} := \text{MerkleVerify}(\text{Poseidon}(H(\text{Aadhaar}), s_A), \text{root}, \pi_A) = 1$

Private: AadhaarHash (hash of Aadhaar number, not raw number), salt s_A , Merkle path π_A

Public: merkleRoot only (signed by issuer, verified by ϕ_{sig})

Legal effect: Proves Aadhaar linkage (mandatory for Full KYC) without revealing the Aadhaar number (Section 29 compliance)

9 IT Act 2000 and Related Provisions

§ IT Act 2000 — Relevant Sections

Section 43A: Compensation for Failure to Protect Data

A body corporate that possesses, deals with, or handles sensitive personal data in a computer resource that it owns, controls or operates, and is negligent in implementing and maintaining reasonable security practices, is liable to pay compensation. Damages have been awarded up to crores of rupees.

ZKP eliminates this liability: The PSP does not store KYC documents. There is nothing to breach. Section 43A liability is structurally nullified.

Section 72A: Punishment for Disclosure of Information in Breach of Lawful Contract

Disclosure of personal information without consent: imprisonment up to 3 years or fine up to Rs. 5 lakh or both.

ZKP compliance: PSP cannot disclose what it does not possess.

Information Technology (Reasonable Security Practices and Procedures and Sensitive Personal Data or Information) Rules, 2011

Rule 3 defines “sensitive personal data” to include:

- Financial information (bank account, credit card, debit card)
- Physical, physiological, and mental health condition
- Biometric information

All of the above appear in traditional KYC. ZKP eliminates their transmission to the PSP layer entirely.

10 Master Predicate Table: Regulations → Circuit

Regulation Clause	&	Legal Requirement	Circuit Predicate	Private / Public
RBI KYC Para 13(a) Q: currentYear, maxValidity		DOB must be verified; age ≥ 18 for account	$\phi_{\text{age}}:$ $\text{currentYear} - \text{birthYear} \geq \text{minAge}$	P: birthYear Q: currentYear, minAge
RBI KYC Para 13(b)		Identity via valid OVD (7 types)	$\phi_{\text{doc}}:$ docType $\in [1, 7]$	P: docType Q: nothing
RBI KYC Para 13(c)		PAN mandatory (Full KYC)	$\phi_{\text{pan}}:$ $\text{Poseidon}(\text{PAN}, s) \in \text{MerkleTree}$	P: PAN hash, salt, path Q: merkleRoot
RBI KYC Para 13(d)		Aadhaar for digital KYC	$\phi_{\text{aadhaar}}:$ $\text{Poseidon}(\text{H}(\text{Aadhaar}), s) \in \text{MerkleTree}$	P: Aadhaar hash, salt, path Q: merkleRoot
RBI KYC Para 27		Risk categorisation via income/occupation	$\phi_{\text{income}}:$ incomeClass $\in [1, 3]$ (Full KYC)	P: incomeClass Q: nothing
RBI KYC Para 38		Credential validity period (10yr low-risk)	$\phi_{\text{fresh}}:$ $\text{credAge} \leq \text{maxValidityYears}$	P: issuanceYear Q: currentYear, maxValidity
PMLA Rule 9A Q: pk_I , merkle-Root		Identity verified by Regulated Entity	$\phi_{\text{sig}}:$ $\text{EdDSA.Verify}(pk_I, \text{root}, \sigma) = 1$	P: $\sigma = (R_8, S)$
PMLA Rule 9		Audit trail for 10 years	On-chain event log (Verifier contract)	Q: proof hash, timestamp

Regulation Clause	&	Legal Requirement	Circuit Predicate	Private / Public
Aadhaar Act S.29 Q: nothing		Aadhaar number not shared	ϕ_{aadhaar} : uses $H(\text{Aadhaar})$, not raw number	P: Aadhaar hash (one-way)
NPCI UPI Circular Q: txAmount, tier-Limit		Transaction $\leq$ tier limit	ϕ_{limit} : txAmount $\leq$ tierLimit	P: nothing
NPCI UPI Circular Q: tierThreshold		Full KYC tier required for >Rs.10K	ϕ_{tier} : tier $\geq$ tierThreshold	P: all attributes
DPDP Act S.8(3)		Data minimisation — only necessary data	Zero-knowledge property of Groth16	Formal ZK guarantee
IT Act S.43A		Data breach liability	PSP stores nothing personal	Structural compliance
Anti-replay (NPCI)		Proofs must not be reused	ϕ_{nonce} : boundHash = Poseidon(nonce, root)	P: nothing Q: nonce, bound-Hash
Revocation (RBI KYC)		Revoked credentials invalid	ϕ_{revoc} : credNullifier $\notin$ SMT	P: SMT path Q: revocRoot, nullifier

11 What the Circuit Must Incorporate: Summary

✓ Complete List of Circuit Predicates Required by Indian Law

Mandatory for Full KYC Proof:

1. ϕ_{age} — Age ≥ 18 (RBI KYC Para 13a, legal majority)
2. ϕ_{income} — Income class $\in \{1, 2, 3\}$ (RBI KYC Para 27, risk classification)
3. ϕ_{doc} — Document type is valid OVD (RBI KYC Para 13b)
4. ϕ_{pan} — PAN commitment is in signed Merkle tree (RBI KYC Para 13c)

5. ϕ_{aadhaar} — Aadhaar commitment is in signed Merkle tree (Aadhaar Act S.8)
6. ϕ_{sig} — Credential signed by registered issuer (PMLA Rule 9A)
7. ϕ_{fresh} — Credential issued within 10 years (RBI KYC Para 38)
8. ϕ_{revoc} — Credential not in revocation SMT (RBI continuous monitoring)
9. ϕ_{nonce} — Proof bound to PSP's challenge nonce (anti-replay, NPCI)
10. ϕ_{tier} — Computed tier $\geq$ threshold (NPCI UPI Circular)
11. ϕ_{limit} — Transaction amount $\leq$ tier limit (NPCI UPI Circular)

For Minimum KYC (relaxed):

1. ϕ_{age} — Age ≥ 18 (same as Full KYC)
2. $\phi_{\text{income}}^{\text{min}}$ — Income class $\in \{1, 2, 3, 4\}$ (includes students)
3. ϕ_{doc} — At least one valid OVD
4. ϕ_{sig} — Issuer signature valid
5. $\phi_{\text{limit}}^{\text{min}}$ — Transaction amount $\leq$ Rs. 10,000

Additional for Extension Module (NACH, FASTag, RuPay):

1. $\phi_{\text{residence}}$ — Residence status for NRI/UPI One World
2. ϕ_{noPEP} — Holder is not a Politically Exposed Person (RBI KYC Para 27)
3. ϕ_{cibil} — Credit score above threshold (for RuPay credit on UPI)